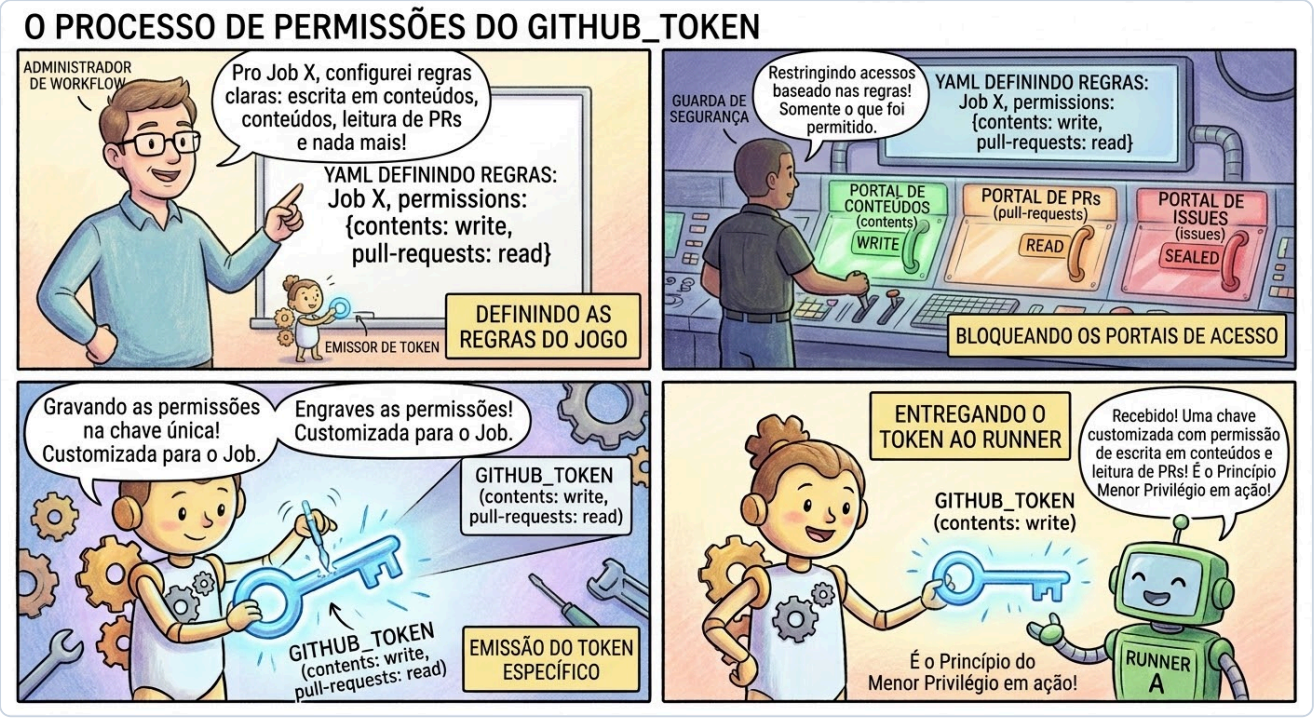
Arquitetura de Segurança: GITHUB_TOKEN & Permissões

Guia Visual e Técnico para a Certificação GH-200

> **O Conceito Central:** O `GITHUB_TOKEN` é um credencial/crachá de acesso temporário injetado automaticamente pelo GitHub em cada job. Ele permite que o *Runner* interaja com as APIs do GitHub de forma segura e autêntica. Através do bloco `permissions:`, nós definimos rigorosamente o **Princípio do Menor Privilégio**.

Parte 1: A Emissão e Concessão da Chave de Acesso

Antes do Runner iniciar a execução, o gerenciador do workflow avalia as regras contidas no arquivo YAML. O emissor cria uma chave única com permissões sob medida e a entrega ao Runner.



Parte 2: O Runner em Ação com as Permissões Granulares

De posse do token customizado, o Runner dirige-se aos portais de API do repositório. Ele consegue executar tarefas permitidas (como criar tags e releases em `contents: write`) enquanto acessos não autorizados permanecem bloqueados.



Tabela de Referência de Escopos (GH-200)

Escopo	O que autoriza?	Exemplo de Uso
`contents`	Commits, tags, branches e criação de Releases	`contents: write`
`pull-requests`	Comentar, aprovar, mesclar e atribuir revisores em PRs	`pull-requests: write`
`issues`	Criar, fechar e gerenciar issues do repositório	`issues: write`
`packages`	Publicar e baixar pacotes no GHCR (GitHub Packages)	`packages: write`
`id-token`	Emitir token OIDC para conexão segura com AWS/Azure/GCP	`id-token: write`